

Projeto 03A

Unidade Curricular de Segurança

Artur Meireles de Sousa Falcão

a2024130485@isec.pt

2024130485

Data de entrega: 17/03/2026

Tempo de realização: ~6h

1. CVE-2023-32360 (data de publicação: 23/06/2023)

Trata-se de uma falha de segurança no subsistema de impressão (CUPS) dos sistemas operativos Apple macOS. Devido a uma má gestão de estado na autenticação, a vulnerabilidade permite que um utilizador local com baixos privilégios consiga contornar as restrições e aceder a documentos recentemente impressos por outros utilizadores, resultando numa grave quebra de confidencialidade de informação.

Vetor de Ataque: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

AV:L (Attack Vector: Local): O atacante precisa de ter acesso local ao Mac afetado.

AC:L (Attack Complexity: Low): A complexidade do ataque é baixa, o que não requer condições difíceis para ser executado com sucesso.

PR:L (Privileges Required: Low): O atacante necessita apenas de privilégios básicos no sistema.

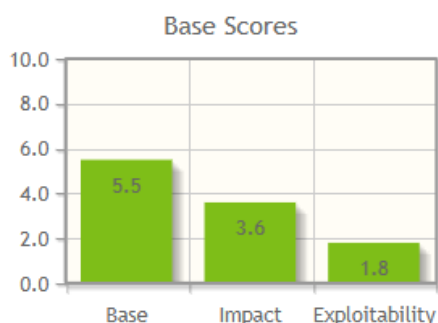
UI:N (User Interaction: None): Não requer que a vítima realize qualquer ação.

S:U (Scope: Unchanged): A falha afeta apenas o componente vulnerável.

C:H (Confidentiality: High): O impacto na confidencialidade é alto, pois há fuga total de informação dos documentos impressos.

I:N (Integrity: None): O atacante não consegue alterar documentos, ou seja, não há impacto na integridade.

A:N (Availability: None): Nenhum impacto na disponibilidade, ou seja, o sistema de impressão não deixa de funcionar.



De acordo com o ficheiro CSV, a pontuação EPSS atual para o CVE-2023-32360 é de 0.00064 e encontra-se no percentil 0.19739. Comparando este valor com os dados de há um mês (0.00064 / 0.19861) e de há um ano (0.00045 / 0.18399), verifica-se que o score EPSS se tem mantido perto do limite mínimo do algoritmo. A conclusão retirada é que não existe exploração ativa em massa para esta vulnerabilidade.

CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

Esta fraqueza ocorre quando um sistema expõe intencionalmente ou acidentalmente dados sensíveis a agentes que não possuem as devidas autorizações de acesso.

A falha no sistema CUPS materializa exatamente esta fraqueza. Ao permitir que um utilizador local contorne o processo de autenticação e consiga extrair documentos da fila de impressão de terceiros, o sistema está a expor diretamente informação confidencial e sensível a um ator não autorizado.

2. Para obter a lista de utilizadores criados devo usar o comando: “show running-config | include username”.

3. Último quadro capturado: PDU nº48.

Linhas 1-26: As PDUs iniciais correspondem ao arranque dos equipamentos (ICMPv6 / Gratuitos ARP / CDP).

Linhas 27-28: Ao executar o comando SSH para o IP 192.168.1.50 no A1, este envia um ARP Request em Broadcast, ao qual o router R1 responde com um ARP Reply indicando o seu endereço MAC 06:23:04:85:aa:f1.

Linhas 29-31: Inicia-se a ligação TCP para a porta 22. A ligação TCP fica estabelecida após o three-way handshake onde o A1 envia o pacote de sincronização [SYN], o R1 responde com [SYN, ACK] e acaba com o A1 a enviar o [ACK] final.

Linhas 32-37: As duas máquinas trocam as suas Version Strings (Protocol), em que o A1 diz ser um cliente OpenSSH_9.2p1 Debian e o R1 um servidor Cisco-1.25, seguindo-se os respetivos ACKs confirmando a receção destas mensagens.

Linhas 38-41: Ambos enviam Key Exchange Init que contém as listas de algoritmos criptográficos que suportam, e de seguida confirmam a receção através dos [ACK].

Linhas 42-48: A1 inicia a troca de chaves Diffie-Hellman (Diffie-Hellman Key Exchange Init) e o R1 responde com a sua chave pública no pacote Diffie-Hellman Key Exchange Reply. A1 analisa o seu ficheiro known_hosts, e, ao não encontrar lá a chave, suspende o processo no terminal e solicita a intervenção do utilizador “Are you sure you want to continue...”. R1 envia a mensagem New Keys para indicar que está pronto a usar as chaves geradas para encriptar o tráfego.

4. Em rigor, ao aceitarmos a chave sem a validar previamente por um canal isolado, estamos vulneráveis a ataques MITM (Man-in-the-Middle), como abordado no documento RFC 4253: “C is also allowed to accept the key without verification; however, doing so will render the protocol insecure against active attacks (but may be desirable for practical reasons in the short term in many environments).”.

Ao responder “yes” a ligação passa a estar encriptada, o que leva o Wireshark a interpretar as mensagens como Encrypted packet (linhas 1, 4, 6, 8, 9, 10 e 11). Observa-se ainda as mensagens de confirmação [ACK] (linhas 3, 7 e 12) que indicam a receção dos pacotes, e correções do próprio TCP (linhas 2 e 5).

5. A execução do comando “ls -l ~/.ssh/known_hosts” confirmou a criação do ficheiro known_hosts pelo sistema, e, ao analisar o seu conteúdo através do comando “cat ~/.ssh/known_hosts” comprova-se que a chave pública do servidor foi guardada e associado a aquele destino.

```
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.50' (RSA) to the list of known hosts.
(admina485@192.168.1.50) Password:

[1]+  Stopped                  ssh admina485@192.168.1.50
root@Al:~# ls -l ~/.ssh/known_hosts
-rw-r--r-- 1 root root 442 Mar 12 11:03 ~/.ssh/known_hosts
root@Al:~# cat ~/.ssh/known_hosts
|1|dq89eu6TFLFrQLCRdzAttt2FpGU=|S6IJar+DzK7dRdCLcPDHkQTemTo= ssh-rsa AAAAB3NzaClyc2EAAAADAQABAAQDIatKdsrGx
T5gVhw5DxmP528Q0ntqeoov3jHBXzU/0rHpOBy8Se14pOthjflqZptR3kah7TdKpJONOVKcDLANS7RFIrwBAHQ/xxz+RYTvtAmCD1bNgMAEBi
iacCsiwixidbsx008wrH5zDcIfqkjVUPZ7j7ND6FNptaCxa4IpQvNiY3s1Q4HPBFfeBlyTmuVgfBxqWuyW/WZ6H2hGkTPlEJEJP5CgAJmD9CyYi
HCSBJlG4MplKozI4OnuILazAkolRWGdNySRdJAF52DAK1PKXuOBKAMs1R3QT+dcXnhpu485+M0R0LHQbLb2qsM91VZt8yDy6haeQDqZg4SdN
8Rvgn
```

6. Última PDU capturada: PDU nº 78.

Linhas 2 A 20: A sessão inicia-se com o three-way handshake do TCP, seguido da troca de versões do protocolo SSH e da Key Exchange, e por fim a mensagem New Keys mostra que as chaves de cifra entram em vigor.

Linhas 21 a 71: Todo o tráfego passa a estar encriptado. Sendo aqui que ocorrem os eventos da sessão como a introdução da password, o prompt do router e o envio do comando exit.

Linhas 72 a 78: Após o comando “exit” a ligação na camada de transporte é encerrada, ao o cliente enviar [FIN, ACK], o servidor responder [FIN, PSH, ACK] e o cliente confirmar com [ACK]. As últimas PDUs [RST] encerram a ligação e libertam os sockets.

7. Não foi possível encontrar a senha associada ao primeiro utilizador criado, usando a funcionalidade “Follow TCP Stream” do Wireshark, contrariando o que tinha sido possível fazer com o protocolo Telnet. Esta grande diferença revela-se na confidencialidade dos dados, pois no Telnet toda a comunicação circula em *clear text*, enquanto que no SSH o conteúdo de toda a camada de aplicação é encriptado.



8. O comando “ssh-keygen -F” serve para pesquisar se um determinado IP já tem a sua chave guardada no ficheiro “known-hosts”. Como se observa no output, o IP não está em *clear text*, mas sim encriptado (hash com salt, indicado pelo prefixo [1]). O motivo deste encriptação é para caso um atacante roube este ficheiro, não conseguirá ler os IPs em texto limpo, o que o impede de mapear a rede e descobrir a que servidores este computador se costuma ligar.

```
root@Al:~# date
Sun Mar 15 15:17:11 UTC 2026
root@Al:~# ssh-keygen -F 192.168.1.50
# Host 192.168.1.50 found: line 1
|1|sa0xOCQxcJYQJ+yEA32NGmAFgI0=|g4kCRaBmR0GnI2981AoDpjJmRJo= ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQDIatKdsrGx
T5gVhw5DxmP528Q0ntqeoov3jHBXzU/OrHpOBy8Se14pOthjflqZptR3kah7TdKpJONOVKcDLANS7RFIrWbAHQ/xxz+RYTvtAmCD1bNGmAEBi
iacCsiVx1dbx008wrH5zDtIfqkjVUPZ7j7ND6FNptaCxa4IpQvNiY3slQ4HPBFfeB1YtmuVgfBxqWuyW/WZ6H2hGkTP1EJEp5CgAJMd9CvYi
HCSBJ1G4MplKozI4OnuILazAko1RWGdNySRdJAF52DAK1PKXuOBKam5s1R3QT+dcXnhpu485+MOR01HQbLb2qsM91VZt8yDy6haeQDqZg4SdN
8Rvgn
```

Ao aceder a R1 por SSH através do endereço IP da segunda interface (192.168.2.51) e aceitar a ligação, foi adicionada uma nova entrada no ficheiro “.ssh/known_hosts”. Embora o hash do endereço seja diferente em relação à entrada já consultada atrás, a chave pública é exatamente a mesma, pois estamos a aceder o mesmo equipamento físico (R1). O comando “ssh-keygen -F 192.168.2.51” confirma que o cliente SSH, criou um registo pois trata cada endereço IP como um destino distinto por questões de segurança, mesmo detetando que a chave já era conhecida na rede.

```
root@Al:~# ssh -o KexAlgorithms+=diffie-hellman-group14-shal -o HostKeyAlgorithms+=ssh-rsa admina485@192.168.
2.51
The authenticity of host '192.168.2.51 (192.168.2.51)' can't be established.
RSA key fingerprint is SHA256:h28Q6Zq/mQef29R6HpxLM+j4J4SZNMCO5rHwMDmcyUY.
This host key is known by the following other names/addresses:
~/.ssh/known_hosts:1: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.2.51' (RSA) to the list of known hosts.
(admina485@192.168.2.51) Password:

root@Al:~# ssh-keygen -F 192.168.2.51
# Host 192.168.2.51 found: line 2
|1|iG5q3JZuDNmftZ4pxKVTHvszg8=|hwrRNSwg3nZuz46IFxoFZjFEHJ8= ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQDIatKdsrGx
T5gVhw5DxmP528Q0ntqeoov3jHBXzU/OrHpOBy8Se14pOthjflqZptR3kah7TdKpJONOVKcDLANS7RFIrWbAHQ/xxz+RYTvtAmCD1bNGmAEBi
iacCsiVx1dbx008wrH5zDtIfqkjVUPZ7j7ND6FNptaCxa4IpQvNiY3slQ4HPBFfeB1YtmuVgfBxqWuyW/WZ6H2hGkTP1EJEp5CgAJMd9CvYi
HCSBJ1G4MplKozI4OnuILazAko1RWGdNySRdJAF52DAK1PKXuOBKam5s1R3QT+dcXnhpu485+MOR01HQbLb2qsM91VZt8yDy6haeQDqZg4SdN
8Rvgn
```

9. Não, a pergunta não foi feita, pois a verificação e aceitação da chave pública é feita por equipamento/endereço IP de destino e não por conta de utilizador.

```
root@Al:~# ssh adminb485@192.168.1.50
(adminb485@192.168.1.50) Password:

R1-0485>
```

10.

```
R1-0485#show running | begin parser
parser view ArturFalcao-VIEWA
secret 5 $1$xB6J$0y6EmtVN058JM01LU9WSQ.
commands interface include shutdown
commands interface include ip address
commands interface include ip
commands interface include description
commands configure include interface
commands exec include configure terminal
commands exec include configure
commands configure include interface Ethernet0/1
```

11.

```
R1-0485>show parser view
Current view is 'ArturFalcao-VIEWA'

R1-0485>show privilege
^
% Invalid input detected at '^' marker.
```

12. O sistema de vistas foi configurado com sucesso, sendo que a vista criada “ArturFalcao-VIEWA” foi aplicada exclusivamente ao primeiro utilizador. Como não foi associada nenhuma vista ao segundo utilizador, o sistema AAA aplicou-lhe o comportamento padrão (acesso de nível 1).

```
R1-0485>show parser view
No view is active ! Currently in Privilege Level Context

R1-0485>show privilege
Current privilege level is 1
```